COLORADO
Governor's Office of Information Technology
Serving People. Serving Colorado.

Operations Memorandum

OIT's Authority & Governance

Executive Summary

Information technology (IT) is an essential component of state government, enabling the delivery of critical services to Colorado's residents, businesses and visitors. Since 2008, the Colorado Governor's Office of Information Technology (OIT) has been the enterprise provider of IT support and services to nearly all executive branch agencies. This memorandum highlights the current statutory roles and responsibilities of OIT as well as those of state agencies served by OIT.

Statutory Authority

Colorado Revised Statutes Title 24 Article 37.5 empowers OIT to be the organization it is today. OIT has the statutory authority and responsibility to integrate, coordinate and oversee information technology for the state and state agencies.[1] In July 2008, Senate Bill 08-155 consolidated the delivery of state agency IT services and functions, systems, personnel and assets under OIT. This consolidation reduced the number of disparate and duplicative systems through the deployment of enterprise solutions. Senate Bill 22-191 and House Bill 21-1236 provided additional clarity and further solidified OIT's authority and role in relation to state agency IT. Additionally, Senate Bill 24-224 empowered OIT to promulgate rules to establish a technology life-cycle plan for the state's IT systems and assets. OIT's statutory authority encompasses the following areas:

> ***IT Staff***. OIT oversees the hiring, management, training and performance of all IT personnel in the state who are performing IT functions. This includes IT personnel and contractors who support state agencies to perform IT work. Each state agency is assigned an IT Director who serves as the bridge between the agency and OIT by supporting collaborative decision-making in the procurement, implementation and management of IT systems, services, processes and standards.

[1] As defined in C.R.S. § 24-37.5-102(28)

IT Standards. OIT establishes, maintains, oversees and enforces the IT technical standards and information security policies to which state agencies are accountable. OIT also oversees statewide IT strategy, rates and services, broadband, cybersecurity, and data accessibility to ensure alignment with established state standards and policies.

IT Projects and Project Management. OIT governs all state agency IT projects. Through its authority, OIT develops standards for project management, including risk and change management, and evaluates all IT projects for alignment with state standards, architecture and best practices. OIT ensures that projects are managed by an assigned project manager and that the state agency working on the capital IT project reports to OIT as required. State agencies undertaking major IT projects must work closely with OIT, prior to commencing the project, to develop the project plan and obtain approval from OIT.

Internet-based Government. OIT is charged with developing and encouraging an internet-based state government and facilitating the dissemination of information onto the internet in a secure, accessible and equitably-available manner. OIT works with partners including the Statewide Internet Portal Authority (SIPA) and state agencies to enhance the citizen experience with state government. OIT is implementing a digital government strategic plan to advance statewide adoption of digital government services and increase offerings for these services.

IT Infrastructure, Applications and Systems. OIT ensures cost-effective, efficient, and secure IT systems for state agencies to reduce redundancy, improve interoperability, and meet business needs. OIT also manages the state's IT asset inventory, refresh cycles, and cost projections. Additionally, OIT establishes application development methodology and oversees installation, maintenance, and retirement of IT assets. By Dec. 31, 2024, OIT will establish a technology life-cycle plan for the state.

Chief Information Officer Authority[2]

The Chief Information Officer (CIO) is appointed by the Governor to lead OIT as Executive Director and serve as a member of the Governor's cabinet. The CIO actively monitors trends and advances in IT resources, directs and approves the annual comprehensive statewide IT planning process, and plans for the acquisition, management and use of IT. The CIO advises the Joint Technology Committee (JTC) and Joint Budget Committee (JBC) on new and ongoing IT projects in relation to project contracts, budgets, and timelines and assists the JTC in its oversight of OIT. The CIO has the authority to promulgate rules for the governance of IT, including the standards, policies, procedures and guidelines for the oversight of IT staff, strategy, security, resources, data, projects, systems, infrastructure and applications, as well as to establish IT accessibility standards for individuals with a disability.

Chief Information Security Officer Authority[3]

Statute provides that a Chief Information Security Officer (CISO) within OIT be appointed by the CIO to ensure that the information Coloradans have entrusted to public agencies[4] is safe, secure and protected from unauthorized access, unauthorized use or destruction. The CISO is responsible for establishing and maintaining a robust IT security program for public agencies. This includes developing and updating security standards, policies, and guidelines, and ensuring that agencies incorporate these standards into their IT security plans. The CISO also plays a critical role in incident response, with the authority to temporarily suspend agency operations to resolve security incidents. Additionally, the CISO directs IT security audits, establishes a risk management process to identify vulnerabilities, and deploys mitigation strategies to address those risks.

[2] C.R.S. § 24-37.5-106
[3] C.R.S. § 24-37.5-403, 405
[4] As defined in C.R.S. § 24-37.5-102(26)

Government Data Advisory Board Authority[5]

The CIO or the CIO's delegate serves as a member and Chair of the Government Data Advisory Board (advisory board). In this capacity, the CIO or CIO's delegate is responsible for extending invitations to state agency personnel who are either experts in data or responsible for diverse aspects of data management to serve on the advisory board. The CIO or CIO's delegate is required to schedule meetings of the advisory board as necessary to complete the advisory board's duties, as outlined in statute,[6] and annually report to the JTC on the advisory board's progress, accomplishments and recommendations for future work.

Colorado Broadband Office[7]

The Colorado Broadband Office (CBO) leads the statewide effort to expand broadband coverage and quality for all Coloradans. In 2021, House Bill 21-1289 codified the CBO in OIT and established the authority of the CBO and the office's Executive Director.

State Agency Responsibility

"State agency" includes all of the departments, divisions, commissions, boards, bureaus, and institutions in the executive branch of Colorado state government; however, this does not include the legislative or judicial departments, the departments of education, law, state, and treasury, or state-supported institutions of higher education.[8]

State agency adherence to the IT statutory requirements discussed in this memorandum serves as the state's best defense in mitigating security threats, limiting agency and state contractual and legal liabilities, and ensuring that data is being used and accessed in accordance with state and federal laws. Alignment with statutory requirements also creates streamlined processes and economies of scale that maximize taxpayer resources and

[5] C.R.S. § 24-37.5-702
[6] C.R.S. § 24-37.5-702(3)
[7] C.R.S. § 24-37.5-903. See *Colorado Broadband Office Policy Memorandum* for additional details.
[8] C.R.S. § 24-37.5-102(28)

increase interoperability between state agencies. In relation to IT, state agencies are required to:

- Obtain OIT approval for the procurement, acquisition, contracting, and maintenance of IT resources as well as comply with the rules, standards, plans, policies and directives of OIT.
- Consult with and receive approval from OIT for major IT projects prior to commencing work or changes to the project or project funding strategy or budget.
- Collaborate with OIT in responding to IT requests from the General Assembly, JTC and JBC, and the creation of IT plans and budgets for the state agency.
- Work with OIT to solve business challenges that involve IT systems, vendors and other state agency capabilities.
- Leverage the expertise of the agency IT Director in procuring, understanding and overseeing agency-managed IT projects and systems.
- Ensure mission-driven program delivery and create a business culture that prioritizes maximizing the value of the state's IT projects and resources.
- Request, and periodically audit, appropriate access levels for agency IT system users.
- Include OIT as a party to all contracts or agreements for IT goods, services and systems.
- Hold the authority and responsibility for projects managed by the state agency when OIT is involved only as a party to a contract.[9]
- Facilitate the development and implementation of interdepartmental data protocol.[10]

Public Agency Responsibility

Public agencies also have statutory responsibilities specific to information security. Statute defines "public agency" as "every state office, whether executive or judicial, and all of its respective offices, departments, divisions, commissions, boards, bureaus, and institutions

[9] C.R.S. § 24-37.5-105.2
[10] C.R.S. § 24-37.5-704

[and] does not include institutions of higher education or the general assembly."[11]

Public agencies are required to annually develop an information security plan using the security policies, standards and guidelines developed by the CISO and submit the plan to the CISO for approval by July 15 of each year.[12] The information security plan must provide information security for the communication and information resources that support the operations and assets of the public agency and include the following components:

- Periodic assessments of the risk and magnitude of the harm that could result from a security incident.
- A process for providing adequate information security for the communication and information resources of the public agency.
- Regular security awareness training to inform the employees and users of the public agency's communication and information resources about information security risks and the responsibility of employees and users to comply with agency policies, standards, and procedures designed to reduce those risks.
- Periodic testing and evaluation of the effectiveness of information security for the public agency, which shall be performed not less than annually.
- A process for detecting, reporting, and responding to security incidents consistent with the information security standards, policies, and guidelines issued by the CISO.
- Plans and procedures to ensure the continuity of operations for information resources that support the operations and assets of the public agency in the event of a security incident.[13]

While not included in the definition of "public agency" both the general assembly[14] and institutions of higher education[15] are also required to implement information security plans in accordance with statutory requirements.

---

[11] C.R.S. § 24-37.5-102(26)
[12] C.R.S. § 24-37.5-404(3)
[13] C.R.S. § 24-37.5-404, *et. seq.*
[14] C.R.S. § 24-37.5-404.7, *et seq.*
[15] C.R.S. § 24-37.5-404.5, *et. seq.*